

M.A.R.K. Sentinel — Compliance Report

Generated:

Executive summary

M.A.R.K. Sentinel — Compliance Report Generated: 2026-04-30T01:01:05Z Profile: SMB Basic ## Summary Total checks: 13 Passes: 8 Failures: 4
Findings ### AI-DEPLOY (6) - **AI-DEPLOY-001 — API Keys Not Exposed** — - Description: No API keys detected in source files. .gitignore protects .env files. - Framework mappings: OWASP LLM/LLM07, FedRAMP/IA-5, NIST AI RMF/MANAGE 2.2, FedRAMP/AC-2, FedRAMP/AC-3, FedRAMP/AU-2 - Evidence: ['.gitignore found with .env protection', '1 .env file(s) present (correct storage location)'] - **AI-DEPLOY-002 — No Hardcoded Credentials in Model Config** — - Description: No hardcoded credentials detected in config files.

M.A.R.K. Sentinel — Compliance Report
Generated: 2026-04-30T01:01:05Z
Profile: SMB Basic

Summary
Total checks: 13
Passes: 8
Failures: 4

Findings

AI-DEPLOY (6)

- **AI-DEPLOY-001 — API Keys Not Exposed** —
 - Description: No API keys detected in source files. .gitignore protects .env files.
 - Framework mappings: OWASP LLM/LLM07, FedRAMP/IA-5, NIST AI RMF/MANAGE 2.2, FedRAMP/AC-2, FedRAMP/AC-3, FedRAMP/AU-2
 - Evidence: ['.gitignore found with .env protection', '1 .env file(s) present (correct storage location)']
- **AI-DEPLOY-002 — No Hardcoded Credentials in Model Config** —
 - Description: No hardcoded credentials detected in config files.
 - Framework mappings: OWASP LLM/LLM07, FedRAMP/IA-5, FedRAMP/CM-6, NIST AI RMF/MANAGE 2.2, FedRAMP/CM-2, FedRAMP/AC-3
 - Evidence: ['Environment variable references found (\${} style) — credentials correctly externalized', '1 .env file(s) present for secret storage']
- **AI-DEPLOY-003 — Logging Enabled and Retained** —
 - Description: Logging configuration and retention settings found.
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/AU-2, FedRAMP/AU-11, NIST AI RMF/MEASURE 2.5, FedRAMP/AU-6, FedRAMP/SI-4
 - Evidence: ['Logging patterns matched: 4', 'Log retention configuration present']
- **AI-DEPLOY-004 — Access Controls on AI Endpoint** —
 - Description: Authentication configuration found in deployment files.
 - Framework mappings: OWASP LLM/LLM07, FedRAMP/AC-3, NIST AI RMF/GOVERN 1.1, FedRAMP/SC-7, FedRAMP/IA-2
 - Evidence: ['Authentication configuration detected']
- **AI-DEPLOY-005 — TLS/HTTPS Enforced on All AI Connections** —
 - Description: TLS configuration found in deployment files.
 - Framework mappings: OWASP LLM/LLM08, FedRAMP/SC-8, NIST AI RMF/MANAGE 2.2, FedRAMP/SC-13, FedRAMP/SI-10
 - Evidence: ['TLS/SSL configuration detected']
- **AI-DEPLOY-006 — Rate Limiting Configured** —
 - Description: Rate limiting configuration found in deployment files.
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/SC-5, NIST AI RMF/MANAGE 2.2, FedRAMP/SC-7, FedRAMP/SI-4
 - Evidence: ['Rate limiting patterns detected in config']

AI-GOV (4)

- **AI-GOV-001 — AI Usage Policy Documented** — 
 - Description: No AI usage policy found. Without a policy, there is no basis for enforcement, no guidance for employees, and no compliance evidence.
 - Remediation: 1. Draft a minimal AI policy (even one page): approved tools, prohibited data types, responsible party.
 - 2. Have legal/compliance review for industry-specific requirements (HIPAA, PCI, GDPR).
 - 3. Communicate to all employees and collect acknowledgment.
 - 4. Publish in your internal wiki and set a 12-month review reminder.
 - 5. M.A.R.K. Sentinel provides a policy template in docs/SMB_GUIDE.md.
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/PL-1, NIST AI RMF/GOVERN 1.1, EU AI Act/Article 9, FedRAMP/PL-2
 - Evidence: ['No AI usage policy file found (looked for: ai_usage_policy.md, ai_policy.*, usage_policy.*)', 'Policies should define: approved tools, prohibited uses, data classification, responsible party']
- **AI-GOV-002 — Data Retention Policy Covers AI Interactions** — 
 - Description: No data retention policy covering AI interactions found. GDPR, HIPAA, and CCPA all require knowing where AI interaction data is stored and how long it is kept.
 - Remediation: 1. Audit where AI interaction data is stored: logs, vector store embeddings, provider-side storage.
 - 2. Add AI data categories to your retention policy with defined retention periods.
 - 3. Configure technical enforcement: log rotation, vector store TTLs.
 - 4. Check your AI provider's data retention settings — configure minimum retention.
 - 5. Document the deletion process for AI data in your data subject rights procedure.
 - Framework mappings: OWASP LLM/LLM02, FedRAMP/SI-12, FedRAMP/AU-11, NIST AI RMF/GOVERN 1.1, GDPR/Article 5(1)(e), FedRAMP/MP-6, FedRAMP/PL-2
 - Evidence: ['No data retention policy found (looked for: data_retention.md, retention_policy.*, ai_retention.*)', 'Policy should cover: AI logs, conversation history, embeddings, fine-tuning datasets']
- **AI-GOV-003 — AI Incident Response Plan Exists** — 
 - Description: No AI incident response plan found. If your AI leaks data, gets injected, or misbehaves, you need a plan ready before that happens.
 - Remediation: Answer these 5 questions in a document:
 1. What counts as an AI incident? (data leak, injection attack, model misbehavior)
 2. Who do I call first? (internal team + AI vendor security contact)
 3. How do I disable AI quickly? (document the kill switch)
 4. How do I preserve evidence? (export logs before clearing)
 5. Who needs to be notified? (legal, affected users, regulators if required)
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/IR-1, FedRAMP/IR-4, NIST AI RMF/MANAGE 4.1, FedRAMP/AU-6
 - Evidence: ['No IR plan found (looked for: incident_response.md, ir_plan.*, ai_incident.*)', 'An AI IR plan should cover: how to disable AI quickly, who to notify, how to preserve evidence']
- **AI-GOV-005 — AI System Documented in Asset Inventory** — 
 - Description: No AI asset inventory found. An AI system not in inventory cannot be managed, monitored, updated, or secured.
 - Remediation: 1. Start with a simple spreadsheet or Markdown table: System, Provider, Model, Version, Owner, Data Processed.
 - 2. Include ALL AI: externally-hosted APIs, local models, and AI features in approved software (Copilot, Gemini).
 - 3. Build inventory maintenance into change management: no new AI deployment without an inventory entry.
 - 4. Review quarterly — remove decommissioned systems, add newly discovered shadow AI.
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/CM-8, NIST AI RMF/GOVERN 2.2, EU AI Act/Article 60, FedRAMP/CM-2, FedRAMP/PL-2
 - Evidence: ['No inventory file found (looked for: ai_inventory.md, ai_asset_inventory.md, aibom.*)', 'Inventory should include: system name, provider, model version, purpose, owner, data processed']

AI-INP (1)

- **AI-INP-005 — Input Length and Token Limits Enforced** —
 - Description: Input limit configuration found in deployment files.
 - Framework mappings: OWASP LLM/LLM10, FedRAMP/SI-10, NIST AI RMF/MANAGE 2.2, FedRAMP/SI-4, FedRAMP/SC-5
 - Evidence: ['max_tokens or input length limit configuration detected']

AI-SUPPLY (2)

- **AI-SUPPLY-003 — Dependencies from Approved Sources Only** — 
 - Description: No requirements.txt found. Cannot audit Python dependencies.
 - Remediation: Create a requirements.txt with pinned versions for all dependencies.
- For Node.js: ensure package-lock.json is committed.
- Run 'pip audit' or 'npm audit' to check for known vulnerabilities.
- Framework mappings: OWASP LLM/LLM03, FedRAMP/SA-12, FedRAMP/CM-7, NIST AI RMF/GOVERN 2.2, FedRAMP/CM-2, FedRAMP/CM-6, FedRAMP/SI-7
- Evidence: ['No requirements.txt or requirements*.txt found in target directory']
- **AI-SUPPLY-005 — Model Version Pinned (Not Floating Latest)** —
 - Description: Model versions appear to be pinned to specific version identifiers.
 - Framework mappings: OWASP LLM/LLM03, FedRAMP/CM-6, NIST AI RMF/GOVERN 2.2, FedRAMP/CM-2
 - Evidence: ['config.json — "model": "gpt-4o-2024-11-20"']

